ISACA · Governança de TI

COBIT 2019

Control Objectives for Information and Related Technologies

Governança e Gestão de TI Corporativa

Turma de TI & Governança · Março 2026

Agenda

O que vamos ver hoje

01
Introdução ao COBIT
O que é, por que existe, quem usa e a distinção entre Governança e Gestão

02
Princípios
Os 6 princípios do sistema de governança e do framework

03
COBIT 5 vs 2019
Evolução, Design Factors e nova escala de maturidade CPM

04
Benefícios e Comparativo
Valor gerado e COBIT vs ITIL vs ISO ISO vs NIST

05
Implementação na Prática
Como aplicar, caso prático e o assessment de maturidade

O que é COBIT?

O framework global de Governança de TI

Criado pela ISACA em 1996 — presente em mais de 180 países

COBIT

Control Objectives for Information and Related Technologies

Framework internacional de governança e gestão de TI que ajuda organizações a alinhar a TI com os objetivos do negócio, gerenciar riscos, garantir conformidade e demonstrar valor dos investimentos em tecnologia.

ISACA

Criado e mantido pela ISACA — Information Systems Audit and Control Association

O problema que o COBIT resolve

- **"Projetos de TI fracassando"** — sem padrão de gestão e governança
- **"Riscos de segurança ignorados"** — sem mecanismos de controle
- **"Investimentos sem retorno"** — TI sem accountability para o negócio
- **"Auditores sem parâmetros"** — impossível avaliar controles de TI

A ISACA criou o COBIT como resposta a esse caos — e ele evoluiu até se tornar o padrão global.

Entendendo o COBIT

O que o COBIT é — e o que NÃO é

❌ NÃO é	✅ É
❌ Metodologia de desenvolvimento	✅ Framework de governança
❌ Substituto do ITIL	✅ Complementar ao ITIL
❌ Norma técnica como a ISO	✅ Guia de melhores práticas
❌ Obrigatório por lei	✅ Voluntário (mas exigido por reguladores)
❌ Um software ou ferramenta	✅ Conjunto de boas práticas
❌ Só para grandes empresas	✅ Aplicável a qualquer porte

Quem usa o COBIT?

🏦
Bancos e Financeiras
conformidade com Banco Central, SOX, Basileia

🏢
Empresas Privadas
governança de TI e auditoria interna

🏛️
Governo e Setor Público
transparência e controle de gastos com TI

🔍
Consultorias
Deloitte, KPMG, PwC usam como base de assessments

👔
Auditores
avaliação de controles de TI em auditorias externas

Distinção Fundamental

Governança vs Gestão

A diferença mais importante que o COBIT estabelece

🏛 GOVERNANÇA
Domínio EDM

- **Quem faz:** → Conselho, Diretoria, Board
- **O que faz:** → Avalia, Direciona e Monitora
- **Pergunta:** → Estamos indo na direção certa?
- **Exemplo:** → Aprovar estratégia de migração para cloud
- **Frequência:** → Decisões estratégicas, menos frequentes

5 objetivos no domínio EDM

⚙ GESTÃO
Domínios APO · BAI · DSS · MEA

- **Quem faz:** → CIO, Gerentes, Equipes de TI
- **O que faz:** → Planeja, Executa e Controla
- **Pergunta:** → Estamos fazendo da forma certa?
- **Exemplo:** → Executar a migração dos sistemas para cloud
- **Frequência:** → Operações do dia a dia

35 objetivos nos domínios de gestão

⚽ **Analogia do Futebol:**
O conselho do clube GOVERNA — define regras, aprova orçamento, avalia resultados. O técnico e os jogadores GERENCIAM — treinam, executam, entram em campo. Um não substitui o outro — ambos são essenciais.

Histórico

Evolução do COBIT

1996
COBIT 1
Foco em auditoria de sistemas

1998
COBIT 2
Ferramentas e técnicas de gestão

2000
COBIT 3
Inclusão de modelo de maturidade

2005
COBIT 4.1
Alinhamento TI × negócio

2012
COBIT 5
5 princípios, integração Val IT

2019
COBIT 2019
6 princípios, 40 objetivos, open-source

O COBIT 2019 é a versão mais atual e flexível — permite personalizar a governança ao contexto da organização

Motivação

Por que COBIT?

Como garantir que a TI realmente entrega valor para o negócio, sem desperdiçar recursos e sem criar riscos desnecessários?

> "Sem governança de TI, investimentos em tecnologia tornam-se custos difíceis de justificar e riscos difíceis de controlar.

O COBIT resolve isso fornecendo:

🎯
Alinhamento TI × Negócio
TI suporta objetivos estratégicos

⚖️
Gestão de Riscos
Identifica e mitiga riscos de TI

📋
Conformidade
Facilita LGPD, SOX, ISO

💡
Valor para Stakeholders
Otimiza recursos e ROI

🔄
Responsabilização
Define papéis e accountability

📈
Melhoria Contínua
Modelo de maturidade evolutivo

6 Princípios do Sistema de Governança

Definem os requisitos centrais de qualquer sistema de governança de TI

💎 **01**

Fornecer Valor aos Stakeholders

Criar valor equilibrando benefícios, riscos e recursos

🔄 **02**

Abordagem Holística

Integrar toda a empresa: pessoas, processos, tecnologia

⚡ **03**

Sistema Dinâmico

Adaptar-se continuamente às mudanças do ambiente

⚖️ **04**

Governança ≠ Gestão

Governança direciona e monitora; Gestão executa

🏢 **05**

Adaptado à Empresa

Ajustado ao contexto, porte e maturidade da organização

🔗 **06**

Sistema de Ponta a Ponta

Cobre toda a empresa, TI interna e terceirizada

Princípios — Parte 2

6 Princípios do Framework COBIT

Guiam o design e desenvolvimento do próprio framework

01 Baseado em Modelos Conceituais

Fundamentado em conceitos teóricos sólidos e reconhecidos

02 Aberto e Extensível

Integra-se com ITIL, ISO 27001, NIST e PMBOK

03 Alinhado a Padrões Globais

Compatível com normas internacionais amplamente adotadas

04 Completo em Governança de TI

Cobre todos os aspectos de governança corporativa de TI

05 Focado em Necessidades

Orientado a entregar valor tangível às organizações

06 Define Práticas Mínimas

Estabelece mínimos sem restringir a adaptação

Sistema de Governança (slide anterior) = COMO funciona | Framework (este slide) = COMO foi construído

Comparativo de Versões

COBIT 5 vs COBIT 2019

Mesma base, nova flexibilidade e conceitos modernizados

COBIT 5 Lançado em 2012	VS	COBIT 2019 Lançado em 2019
5 princípios		**6+6 princípios** (sistema + framework)
37 processos		**40 objetivos** de governança e gestão
7 Enablers genéricos		**7 Componentes** específicos
Limitada — modelo fixo		**Alta** — 11 Design Factors
PAM (ISO 15504)		**CPM** baseado em COBIT CMMI
Estático		Open-source, atualizações periódicas
Governança geral		**DevOps**, Cloud, Privacidade de Dados

Mudança de Conceito

Enablers → Componentes

Uma das maiores mudanças estruturais do COBIT 2019

COBIT 5 · 7 Enablers

1. Princípios, Políticas e Frameworks
2. Processos
3. Estruturas Organizacionais
4. Cultura, Ética e Comportamento
5. Informação
6. Serviços, Infraestrutura e Aplicações
7. Pessoas, Habilidades e Competências

COBIT 2019 · 7 Componentes

1. Princípios, Políticas e Frameworks = mantido
2. Processos = mantido
3. Estruturas Organizacionais = mantido
4. Cultura, Ética e Comportamento = mantido
5. Informação = mantido
6. Serviços, Infraestrutura e Aplicações = mantido
7. Pessoas, Habilidades e Competências = mantido

De "habilitadores" para "componentes" —
No COBIT 5 eram genéricos. No 2019 cada componente está vinculado ao seu objetivo específico.

Variantes por contexto —
Uma fintech e um banco podem ter componentes adaptados à sua realidade.

Novidade do COBIT 2019

DESIGN FACTORS

Conceito inexistente no COBIT 5 — a grande inovação de personalização

Os 11 Fatores de Design são variáveis contextuais que definem como cada organização deve projetar seu sistema de governança. Cada empresa tem uma combinação única.

11 Fatores de design únicos para cada organização

No COBIT 5 todas as empresas aplicavam o mesmo modelo. No COBIT 2019 a governança é construída sob medida.

DF01 Estratégia corporativa
Influência a direção

DF02 Metas corporativas
Define objetivos

DF03 Perfil de risco
Avaliação de riscos

DF04 Questões de TI
Desafios tecnológicos

DF05 Cenário de ameaças
Riscos externos

DF06 Requisitos de conformidade
Leis e regulamentos

DF07 Papel da TI
Contribuição para o negócio

DF08 Modelo de sourcing
Terceirização e parcerias

DF09 Métodos de implementação
Abordagens de projeto

DF10 Adoção de tecnologia
Novas tecnologias

DF11 Porte da empresa
Tamanho e complexidade

Gestão de Performance

CPM: Nova Escala de Maturidade

COBIT 5 usava PAM (ISO 15504) — o 2019 adotou o CMMI

0 **Incompleto** · Processo não existe — 10%

1 **Inicial** · Ad hoc e imprevisível — 25%

2 **Gerenciado** · Planejado e controlado — 45%

3 **Definido** · Padronizado e documentado — 62%

4 **Quantitativamente Gerenciado** — 80%

5 **Otimizado** · Melhoria contínua — 100%

NEW:
Áreas de Foco
Guias para Cibersegurança, DevOps, Cloud, Privacidade

NEW: 3
Novos Objetivos
APO14 Dados, BAI11 Projetos, MEA04 Garantia

UPDATED:
Goals Cascade
Simplificado e mais fácil de usar

UPDATED:
Novas Certificações
Foundation, Design, Bridge para COBIT 5

UPDATED:
Estrutura de Processos
Dados e Garantia formalizados

OPEN SOURCE:
Modelo Vivo
Atualizações periódicas pela comunidade ISACA

Benefícios do COBIT

Por que as organizações adotam o COBIT?

🎯 Alinhamento Estratégico

Investimentos de TI alinhados com objetivos de negócio

Estratégia

⚖️ Gestão de Riscos Eficaz

Identifica, avalia e responde a riscos de TI estruturadamente

Riscos

📋 Conformidade Regulatória

Facilita LGPD, SOX, Basel II, ISO — reduz multas e riscos legais

Compliance

💰 Otimização de Recursos

Melhora eficiência no uso de pessoas, tecnologia e orçamento

ROI

👁️ Transparência e Accountability

Visibilidade do desempenho de TI para conselho e auditores

Governança

📈 Melhoria Contínua

Modelo de maturidade para evoluir a governança gradualmente

Maturidade

Comparativo

COBIT vs Outros Frameworks

Entendendo o papel de cada um no ecossistema de TI

Critério	COBIT 2019	ITIL 4	ISO 27001	NIST CSF
Foco	Governança de TI	Gestão de Serviços	Segurança da Informação	Cibersegurança
Escopo	Toda a empresa	Operações e serviços	Sistema de gestão segurança	Infraestrutura crítica
Certificação	Sim — ISACA	Sim — ITIL 4	Sim — Auditoria ISO	Não obrigatória
Compatibilidade	Complementa todos	Complementa COBIT	Complementa COBIT	Complementa ISO
Nível	Estratégico + Tático	Tático + Operacional	Tático + Técnico	Técnico + Operacional
Melhor para	CIO, Conselho, Alta gestão	Service Desk, Operações	CISO, Segurança	Engenheiros de segurança

💡 O COBIT não compete com ITIL, ISO ou NIST — ele os **ORQUESTRA**. Define o **QUÊ** deve ser feito; os outros definem o **COMO**.

Aplicação Prática

Como Implementar o COBIT

Um caminho estruturado em 6 fases para adoção gradual

1 Diagnóstico e Motivação
- Identificar drivers de negócio
- Mapear problemas de TI
- Engajar liderança

→

2 Avaliação do Estado Atual
- Aplicar assessment COBIT
- Medir maturidade
- Identificar gaps

→

3 Definir Metas e Roadmap
- Definir estado-alvo
- Construir roadmap
- Alocar responsabilidades

→

4 Planejamento da Implantação
- Selecionar objetivos
- Adaptar ao contexto
- Treinar equipes

→

5 Execução e Realização
- Implementar práticas
- Monitorar KPIs
- Comunicar resultados

→

6 Revisão e Sustentação
- Revisar resultados
- Lições aprendidas
- Reiniciar ciclo

Comece pelos objetivos mais críticos — não implemente tudo de uma vez

O processo é cíclico — fase 6 realimenta a fase 1

Mudança cultural é essencial — liderança deve estar engajada

Afinal, para que serve o COBIT?

Como garantir que a TI da empresa entrega valor ao negócio, sem desperdiçar recursos e sem criar riscos desnecessários?

O COBIT é o guia de boas práticas que define o **QUÊ fazer**, **QUEM** é **responsável**, **COMO medir** e **COMO gerenciar** a TI.

🏙️ A Empresa

- Colaboradores e clientes
- Processos de negócio
- Sistemas de TI
- Projetos e investimentos

=

📐 O COBIT

- Regras de quem aprova o quê
- Padrões de qualidade e segurança
- Planejamento de projetos
- Fiscalização e prestação de contas

💸 Projetos sem controle
Estouram orçamento e prazo

🎯 TI desalinhada
Desenvolve o que o negócio não pediu

🔒 Riscos invisíveis
Vulnerabilidades ignoradas

❓ Sem accountability
Ninguém é responsável quando algo falha

✦ Caso Prático

COBIT na Empresa

Exemplo real: empresa de varejo com problemas de TI

🏬 **Antes do COBIT — empresa de varejo:**

- Sistemas caindo sem plano de continuidade
- Projetos sempre atrasados e acima do orçamento
- Ninguém sabe quem aprova decisões de TI
- Auditoria apontou riscos graves de LGPD

✅ **Após o COBIT:** TI transparente, previsível e alinhada com o negócio. Diretoria confia nos números.

1. **Diagnóstico de maturidade** — Mede nível 0–5 de cada processo. Gestão de riscos = nível 1, Projetos = nível 2
2. **Define prioridades com Design Factors** — Escolhe 5–10 objetivos mais críticos para começar
3. **Cria Comitê de Governança de TI** — Define quem aprova investimentos e monitora riscos
4. **Implementa processos e controles** — Projetos acima de R$50k passam pelo comitê. Relatório mensal de riscos
5. **Mede e melhora continuamente** — KPIs: % projetos no prazo, incidentes, conformidade LGPD

Diagnóstico de TI

O Raio-X da Empresa

Como conduzir um Assessment de Maturidade COBIT

Usando o CPM (COBIT Performance Management), avaliamos cada objetivo com nota de 0 a 5 — revelando onde a empresa está forte e onde precisa melhorar.

Como coletar dados:

🎤 **Entrevistas** — com gestores, diretores e usuários

📄 **Análise de documentos** — políticas, contratos, atas

📝 **Questionários** — templates oficiais da ISACA

🔍 **Observação** — processos de TI em funcionamento

🛠️ Ferramentas disponíveis

● FREE
COBIT Self-Assessment Guide — Documento oficial ISACA

● FREE
ISACA CMMI Platform — Ferramenta online

● PAID
AuditBoard / ServiceNow GRC — Módulos COBIT de mercado

● CONSULTING
Deloitte · KPMG · PwC — Usam COBIT como base

🕒 Tempo por porte

🏠 Pequena empresa → 2 a 4 semanas

🏢 Média empresa → 1 a 3 meses

🏛️ Grande empresa → 3 a 6 meses

📊 O relatório final: Maturidade por processo · Gaps · Riscos prioritários · Roadmap · Quick wins

Resumo Final

COBIT em síntese

O framework que conecta TI e negócio, transformando tecnologia em valor real.

- **Framework** global de governança e gestão de TI criado pela ISACA
- **6 princípios** do sistema + 6 princípios do framework
- **5 domínios** e 40 objetivos de governança e gestão
- **11 Design Factors** para personalizar a governança
- **CPM** — escala de maturidade 0 a 5 baseada em CMMI
- Implementação gradual e adaptável ao contexto da empresa

Dúvidas & Perguntas?

Obrigado pela atenção!

Vamos discutir como o COBIT se aplica a cenários reais de TI no Brasil.

Referência oficial: isaca.org/resources/cobit